Core Application System Security

INSTRUCTIONS:
Please respond to each question by placing an "X" in the "Yes", "No" or "N/A" column or by providing the information requested. Use the "Tab" key to move between items. Use the "Additional information" field for explanatory comments, if necessary. If an item does not have an "Additional information" field, and you need to explain your answer, use the space at the end of the questionnaire and reference the item being explained, e.g. RE: Item 1.2-This is the explanation. If you have questions about completing this questionnaire, please contact Shane Swanson of the Auditing Team.

Questionnaire completed by: _____

Contact number for follow-up questions: _____

Date Completed: _____

1. Policies and Procedures

Number	Question	Developed			Implemented			Board Approved		
	Have the following policies and procedures been documented, approved by the Board of Directors, and implemented within the organization:	Yes	No	N/A	Yes	No	N/A	Yes	No	N/A
1.1	**Logical Access Control Policies:**									
1.1.1	For granting and removing access to the core processing system? Additional information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.1.2	For controlling administrator (Root) level access to the core processing system? Additional information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.1.3	Addressing the regular review of access privileges? Additional information:	☐	☐	☐	☐	☐	☐	☐	☐	☐

Number	Question	Developed			Implemented			Board Approved		
	Have the following policies and procedures been documented, approved by the Board of Directors, and implemented within the organization:	**Yes**	**No**	**N/A**	**Yes**	**No**	**N/A**	**Yes**	**No**	**N/A**
1.1.4	For reclassifying/reauthorizing teller/administrative functions? Additional information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.1.5	Restricting personnel from performing inquiries and transactions on their accounts, family accounts, other employee accounts? Additional information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.2	**Physical Access Control Policies**									
1.2.1	Addressing the use of PCs, Internet access and member information? Additional Information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.2.2	Addressing unauthorized access to secured and/or restricted areas (i.e. the Data Center)? Additional Information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.2.3	Addressing 3rd party physical access to systems and data? Additional Information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.3	**Reports & Error Reporting Policies**									
1.3.1	For reporting processing problems/errors? (*Please provide the auditor with evidence that processing problems and errors are being reported. Evidence may be in the form or error/problem logs*) Additional Information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.3.2	For the regular review of teller activity reports? Additional Information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.3.3	For the regular review of supervisory override reports? Additional Information:	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.4	**Change Management Policies**									
1.4.1	Addressing authorized application changes? (i.e. Parameter settings,	☐	☐	☐	☐	☐	☐	☐	☐	☐

Number	Question	Developed			Implemented			Board Approved		
	Have the following policies and procedures been documented, approved by the Board of Directors, and implemented within the organization:	**Yes**	**No**	**N/A**	**Yes**	**No**	**N/A**	**Yes**	**No**	**N/A**
	open/closed file changes, etc.) (*Please provide the auditor with copies of reviewed and approved application changes.*) Additional Information: _____									
1.4.2	For initiating and completing emergency changes? Additional Information: _____	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.4.3	Procedures governing emergency changes that include the following: ☐ Who is authorized to make emergency changes ☐ The documentation required to initiate and complete emergency changes. Additional Information: _____	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.5	**3rd Party Remote Access Control Policies**									
1.5.1	Remote access policies and procedures for granting and controlling 3rd party remote access? Additional Information: _____	☐	☐	☐	☐	☐	☐	☐	☐	☐
1.6	**BCP/DRP & System(s) Documentation Pol.**									
1.6.1	For updating system documentation? Additional Information: _____	☐	☐	☐	☐	☐	☐	☐	☐	☐

Number	Question	Developed			Implemented			Board Approved		
	Have the following policies and procedures been documented, approved by the Board of Directors, and implemented within the organization:	**Yes**	**No**	**N/A**	**Yes**	**No**	**N/A**	**Yes**	**No**	**N/A**
1.6.2	Business Continuity/Disaster Recovery policies that include the following: ☐ Business Continuity Plan/Disaster Recovery Plan Development? ☐ BCP/DRP Annual Review and Board Approval? ☐ BCP/DRP Training for Employees? ☐ BCP/DRP Annual Testing Additional Information: _____	☐	☐	☐	☐	☐	☐	☐	☐	☐
	Please provide copies of any/all policies and procedures in force and any evidence requested. The documentation will be returned when the Auditors finish their field work.									

2. Core Processing – Logical Security Controls

Number	Question	Yes	No	N/A
2.1	Are users required to enter a unique user ID and password to authenticate to the core processing system? Additional information: _____	☐	☐	☐
2.2	Are teller and administrative functions segregated? (*Please provide evidence that segregation of duties is occurring between tellers and administrators. This evidence may be in the form of an organizational chart and/or formal job descriptions.*) Additional information: _____	☐	☐	☐
2.3	How does the client treat dormant accounts? (*Please provide the auditor any procedures, or system documentation on disabling, or maintaining dormant accounts*) Additional Information: _____			
2.4	Are PC/Workstations connected to the core processing system set to automatically log off users after a specified period of inactivity? Additional Information: _____	☐	☐	☐

Number	Question	Yes	No	N/A
	Please provide copies of all related procedures and evidence requested. The documentation will be returned when the Auditors finish their field work.			

3. Core Processing – Physical Security Controls

Number	Question	Yes	No	N/A
3.1	Are PC/Workstations that have access to the core processing system located in a secure area? Additional information:	☐	☐	☐
3.2	How does the organization restrict access to the Data Center? (*Please provide evidence that data center access is being restricted to authorized personnel. This evidence may be in the form of access logs, and documentation on the methodology the organization uses to restrict access [i.e. Biometric devices, locks, cipher locks, etc.]*) Additional information:	☐	☐	☐
3.3	Are reports printed out and reviewed by management maintained in a secure location with access restricted to authorized personnel only? (*Please provide evidence that you are restricting access to hard copy and electronic reports generated by the core processing system. This evidence may be in the form of access logs, locking file cabinets, data storage containers)* Additional information:	☐	☐	☐
	Please provide copies of all required Service Level Agreements, policies and procedures in force. The documentation will be returned when the Auditors finish their field work.			

4. Core Processing – Application/System Change Controls

Number	Question	Yes	No	N/A
4.1	Are changes to the core processing system reviewed and approved by management? *(Please provide the auditor with documentation changes to the core processing system are reviewed and approved by management.)* Additional information:	☐	☐	☐
4.2	Are changes to the core processing system tested in a separate test environment, prior to being installed in the production environment? Additional information:	☐	☐	☐
4.3	Does the client perform non-monetary file maintenance to ensure the accuracy of maintenance activity? (*Please provide the*	☐	☐	☐

Number	Question	Yes	No	N/A
	auditor with evidence that non-monetary file maintenance is conducted. Evidence may be in the form of completed and signed/initialed file maintenance requests) Additional Information:			
	Please provide copies of all requested evidence. The documentation will be returned when the Auditors finish their field work.			

5. Core Processing – Report Generation/Review Controls

Number	Question	Yes	No	N/A
5.1	Are Exception reports reviewed and initialed/signed by a member of management? *(Please provide the auditor with copies of signed Exception Reports that have been reviewed.)* Additional information:	☐	☐	☐
5.2	Are Teller Activity reports reviewed and initialed/signed by a member of management? *(Please provide the auditor with copies of signed Exception Reports that have been reviewed.)* Additional information:	☐	☐	☐
5.3	Are Supervisory Override reports reviewed and initialed/signed by a member of management? *(Please provide the auditor with copies of signed Exception Reports that have been reviewed.)* Additional information:	☐	☐	☐
	Please provide copies of all requested reports and procedures in force. The documentation will be returned when the Auditors finish their field work.			

6. Core Processing – Remote Access Controls

Number	Question	Yes	No	N/A
6.1	Does the client maintain a log/report of dial-in sessions documenting the following: ☐ Date/Time Connection is established and closed ☐ IP/MAC Address of connecting system ☐ Nature/Purpose of the session (*Please provide the auditor a copy of your remote access log/report)* Additional information: _____	☐	☐	☐
6.2	Does the client disable remote access to the core processing system once remote access sessions are completed and closed? *(Please provide the auditor with an electronic copy of your remote access configuration files. If the config. files cannot be copied, screen shots of the config. files will suffice.)* Additional information: _____	☐	☐	☐
6.3	Does the client change the remote access password after each remote access session? Additional information: _____	☐	☐	☐
	Please provide copies of all required core processing agreements, procedures and logs/reports requested. The documentation will be returned when the Auditors finish their field work.			

7. Core Processing – System Documentation Controls

Number	Question	Yes	No	N/A
7.1	Does the organization maintain current system documentation on its core processing system? Additional Information: _____	☐	☐	☐
7.2	Is access to system documentation restricted to authorized personnel? (*Please provide the auditor evidence that access to system documentation is restricted. Evidence can be in the form of a check out log*) Additional Information: _____	☐	☐	☐
7.3	Are copies of system documentation stored both, onsite as well as offiste? Additional information: _____	☐	☐	☐
	Please provide copies of all requested evidence. The documentation will be returned when the Auditors finish their field work.			

8. Core Processing – Business Continuity Planning/Disaster Recovery Controls

Number	Question	Yes	No	N/A
8.1	Does the client annually review and test its disaster recovery plan for core processing? (*Please provide the auditor with evidence your disaster recovery plan for core processing has been reviewed and tested. Evidence may be in the form of documented table-top tests, walk-throughs, or alternate processing site testing documentation.*) Additional Information: _____	☐	☐	☐
8.2	Are copies of system documentation maintained at a secure offsite location? Additional Information: _____	☐	☐	☐
8.3	Does the client have an alternate processing site in the event a disaster occurs and they have to relocate? (*Please provide the auditor evidence an alternate processing site exists. Evidence may be in the form or a alternate processing site agreement, or reciprocal agreement with another branch and or client*) ***(If Your Answered No To This Question, Please Proceed To Section 10)*** Additional Information: _____	☐	☐	☐

Number	Question	Yes	No	N/A
8.4	Does the client maintain current copies of the following offsite? ☐ Operating System ☐ Source Programs ☐ Object Programs ☐ Master Files ☐ Transaction Files ☐ Operating Instructions ☐ Critical Forms/Supplies ☐ Business Continuity Plan ☐ Additional information: _____	☐	☐	☐
8.5	Has the client formally documented the following: ☐ System Narratives ☐ System Flowcharts ☐ Forms for Input ☐ Data File Layouts ☐ Data Element Definitions ☐ Data File Retention Instructions ☐ Report Layouts ☐ Data Capture Procedures ☐ Processing Flow Charts ☐ Narrative Description of Each Major Program ☐ Decision Tables ☐ List of Constants, Codes and Tables Used ☐ Source Program Listings ☐ Job Control Language Listing ☐ Sort Parameters ☐ Program Changes ☐ Sample Reports	☐	☐	☐

Number	Question	Yes	No	N/A
	Additional information:			
8.6	Has the client documented input procedures to describe all tasks necessary for the control of transactions processed by SO Systems, including the following: ☐ Input Receipt ☐ Data Entry ☐ Error Correction ☐ Source Document Control ☐ Permanent Record Retention Additional information:	☐	☐	☐
8.7	Is the organization's alternate processing site hot, warm or cold? Additional Information:			
	Please provide copies of all required agreements, procedures in force and documented tests/test results. The documentation will be returned when the Auditors finish their field work.			

9. In-House Core Processing

Number	Question	Yes	No	N/A
9.1	Is the client conducting hardware maintenance on its core processing server? (*Please provide the auditor with copies of hardware maintenance reports*) Additional information:	☐	☐	☐
9.2	Are vendors, responsible for providing hardware maintenance, required to provide your organization an agreed upon and signed service level agreement? (*Please provide the auditor with a copy of your signed and dated SLA.*) Additional information:	☐	☐	☐
9.3	Do remedial equipment maintenance arrangements provide for response to a problem(s) in sufficient time to prevent business disruption? Additional information:	☐	☐	☐
9.4	Does the client document and maintain a record/log of all hardware problems? (*Please provide the auditor with a copy of your record/log of hardware problems.* Additional information:	☐	☐	☐
9.5	Is the vendor responsible for hardware maintenance capable of supplying replacement hardware in the event of a disaster	☑	☑	☑

Number	Question	Yes	No	N/A
	or hardware failure? Additional information: _____			
	Please provide copies of all required Service Level Agreements and procedures in force. The documentation will be returned when the Auditors finish their field work.			

10. Core System Specific Questions (Please indicate which of the following, is your core processing system)

Number	Question									Specify Other
10.1	XP Systems (Sec.11) ☐	SOSystems (Sec.12) ☐	Integrasys (Sec.13) ☐	CubeOL (Sec.14) ☐	Symitar/JHA (Sec.15) ☐	Users, Inc. (Sec.16) ☐	Ultradata (Sec.17) ☐	Summit (Sec.18) ☐	Other ☐	_____

11. XP Systems

Number	Question	Yes	No	N/A
11.1	Are PC/Workstations connecting to XP Systems set to automatically log off after a specified period of inactivity? (*Please provide the auditor with electronic copies of (10) PC/Workstation configuration files that verify automatic log off/session time out has been enabled, if config. files cannot be copied, screen shots of configuration will suffice.*) Additional information: _____	☐	☐	☐
11.2	Are hardware and software maintenance boundaries contractually defined with the XP Systems vendor? Additional information: _____	☐	☐	☐
11.3	Has the organization developed a policy(ies) and procedures for enabling and disabling dial-in connectivity to its core processing system? Additional information: _____	☐	☐	☐
11.4	Has the organization implemented a formal policy(ies) and procedures addressing enabling and disabling dial-in connectivity to its core processing system? Additional information: _____	☐	☐	☐
11.5	Are Root passwords changed after each dial-in session? Additional information: _____	☐	☐	☐
11.6	Has the client developed procedures instructing authorized personnel on when and how to release its root password to XP	☐	☐	☐

Number	Question	Yes	No	N/A
	systems in the event XP should need emergency access to the core processing system? Additional information:			
11.7	Has the client implemented procedures instructing authorized personnel on when and how to release its root password to XP systems in the event XP should need emergency access to the core processing system? Additional information:	☐	☐	☐
11.8	Are shared profiles (1) and (163) password protected? *(Please provide the auditor with the configuration files for profiles (1) and (163) verifying they have been password protected.)*	☐	☐	☐
	Please provide copies of all required agreements, policies and procedures in force. The documentation will be returned when the Auditors finish their field work.			

12. SOSystems

Number	Question	Yes	No	N/A
12.1	Are PC/Workstations connecting to SOSystems set to automatically log off after a specified period of inactivity? (*Please provide the auditor with electronic copies of (10) PC/Workstation configuration files that verify automatic log off/session time out has been enabled, if config. files cannot be copied, screen shots of configuration will suffice.*) Additional information:	☐	☐	☐
12.2	Has the organization developed a policy(ies) and procedures for enabling and disabling dial-in connectivity to its core processing system? Additional information:	☐	☐	☐
12.3	Has the organization implemented a formal policy(ies) and procedures addressing enabling and disabling dial-in connectivity to its core processing system? Additional information:	☐	☐	☐
12.4	Are Root passwords changed after each dial-in session? Additional information:	☐	☐	☐

Number	Question	Yes	No	N/A
12.5	Are SOSystems PC/Workstations set to lock out a user after a specified number of failed login attempts? *(Please provide the auditor with electronic copies of (10) PC/Workstation configuration files that verify automatic lock out has been enabled, if config. files cannot be copied, screen shots of configuration will suffice.)* Additional information:	☐	☐	☐
	Please provide copies of all required agreements, policies and procedures in force. The documentation will be returned when the Auditors finish their field work.			

13. Integrasys

Number	Question	Yes	No	N/A
13.1	Has the client developed a policy(ies) and procedures for communicating telecommunications problems to Integrasys? Additional information:	☐	☐	☐
13.2	Has the client implemented a formal policy(ies) and procedures for communicating telecommunications problems to Integrasys? Additional information:	☐	☐	☐
13.3	Are existing telecommunications solutions in place at the client fault tolerant and include either, line redundancies or alternate methods of communicating and processing transactions through Integrasys? *(Please provide the auditor electronic copies of your network topology verifying the fault tolerance of CU telecommunications lines that can communicate with Integrasys)* Additional information:	☐	☐	☐
13.4	Has the organization designated a specific PC/Workstation authorized to receive reports from Integrasys? ***(If You Answered No, To This Question, Please Proceed To Question to 13.6)*** Additional information:	☐	☐	☐
13.5	Is physical as well as logical access to the PC/Workstation assigned to receive reports from Integrasys limited to authorized personnel? *(Please provide the auditor with evidence that physical and logical access to this system is limited authorized personnel. Evidence may be in the form of a unique password, locked office, etc.)* Additional information:	☐	☐	☐

Number	Question	Yes	No	N/A
13.6	Does the client receive and review daily security access reports? *(Please provide the auditor with copies of reviewed security reports. Reports should indicate management review by signature/initials.)* Additional information:	☐	☐	☐
	Please provide copies of all required agreements, policies and procedures in force. The documentation will be returned when the Auditors finish their field work.			

14. CubeOL

Number	Question	Yes	No	N/A
14.1	Has the client developed a policy(ies) and procedures for segregating duties between DB users, systems administrators and DBMS managers? Additional information:	☐	☐	☐
14.2	Has the client implemented a formal policy(ies) and procedures for segregating duties between DB users, systems administrators and DBMS managers? *(Please provide the auditor with electronic copies of your organizational chart verifying segregation of duties exists between the above named positions. Auditor will also need to pull a random sample of DB users, please provide a list of all DB users)* Additional information:	☐	☐	☐
14.3	Has the default "sa" account password been changed? *(Please provide the auditor with a copy of your configuration file for SQL 'sa' account to verify the password has been changed)* Additional information:	☐	☐	☐
14.4	Has the organization developed policies and procedures for assigning database roles? Additional information:	☐	☐	☐
14.5	Has the organization implemented formal policies and procedures for assigning database roles? Additional information:	☐	☐	☐
14.6	Does the client restrict access to Cube's Authority Matrix to authorized personnel? *(Please provide the auditor with a copy of Cube's Authority Matrices configuration file to verify access to the authority matrix is restricted to authorized personnel and a list of personnel documented as having authority to access the matrix)* Additional information:	☐	☐	☐

Number	Question	Yes	No	N/A
14.7	Has the client developed procedures for verifying the identity of Cube personnel prior to granting them access to the client's Cube processing system? Additional information:	☐	☐	☐
14.8	Has the client implemented formal procedures for verifying the identity of Cube personnel prior to granting them access to the client's Cube processing system? Additional information:	☐	☐	☐
	Please provide copies of all required agreements, policies and procedures in force. The documentation will be returned when the Auditors finish their field work.			

15. Symitar/JHA

Number	Question	Yes	No	N/A
15.1	No Further Questions Are Necessary At This Time	☐	☐	☐
	Please provide copies of all required agreements, policies and procedures in force. The documentation will be returned when the Auditors finish their field work.			

16. Users, Inc.

Number	Question	Yes	No	N/A
16.1	Are hardware and software maintenance boundaries contractually defined with the Users, Inc. vendor? Additional information:	☐	☐	☐
16.2	Has the organization developed a policy(ies) and procedures for enabling and disabling dial-in connectivity to its core processing system? Additional information:	☐	☐	☐
16.3	Has the organization implemented a formal policy(ies) and procedures addressing enabling and disabling dial-in connectivity to its core processing system? Additional information:	☐	☐	☐
16.4	Are Root passwords changed after each dial-in session? Additional information:	☐	☐	☐

Number	Question	Yes	No	N/A
16.5	Does the client restrict access to Users' Authorization System to authorized personnel? *(Please provide the auditor with a copy of Cube's Authority Matrices configuration file to verify access to the authority matrix is restricted to authorized personnel and a list of personnel documented as having authority to access the matrix)* Additional information:	☐	☐	☐
	Please provide copies of all required agreements, policies and procedures in force. The documentation will be returned when the Auditors finish their field work.			

17. Ultradata

Number	Question	Yes	No	N/A
17.1	We Have Not Received A SAS 70 Report on Controls For This System Yet	☐	☐	☐
	Please provide copies of all required agreements, policies and procedures in force and copy of Ultradata's most recent SAS 70 Report. The documentation will be returned when the Auditors finish their field work.			

18. Summit

Number	Question	Yes	No	N/A
18.1	Does the client control access to on-line and batch input processes? *(Please provide the auditor with Summit configuration files for on-line and batch input processes verifying access to this process is restricted to authorized personnel. Also please provide the auditor with a documented list of personnel authorized to perform this on-line and batch input.)* Additional information:	☐	☐	☐
18.2	Has the client developed policies and procedures for initiating and completing on-line and batch input? Additional information:	☐	☐	☐
18.3	Has the client implemented formal policies and procedures for initiating and completing on-line and batch input? Additional information:	☐	☐	☐
18.3	Does the organization review Data Change Reports? *(Please provide copies of Data Change Reports verifying management review and signoff)* Additional information:	☐	☐	☐
18.4	Does the organization retain Data Change Reports?	☐	☐	☐

Number	Question	Yes	No	N/A
	Additional information:			
18.5	Has the organization removed the "ZZ" teller ID from the teller file? *(Please provide the auditor with an system generated list of teller IDs)* Additional information:	☐	☐	☐
18.6	Has the client limited access and use of the following commands: ☐ IDIN ☐ TLID *(Please provide the auditor with a copy of the configuration files for the above commands to verify access to the IDIN and TLID are restricted and a list of personnel documented as having authority to use the IDIN and TLID commands)* Additional information:	☐	☐	☐
18.7	Has the client developed policies and procedures for restricting access to client security files? Additional information:	☐	☐	☐
18.8	Has the client implemented formal policies and procedures for restricting access to client security files? Additional information:	☐	☐	☐
18.9	Has the client implemented formal procedures for verifying the identity of Cube personnel prior to granting them access to the client's Cube processing system? Additional information:	☐	☐	☐
18.10	Does the client restrict access to the DRCL command? *(Please provide the auditor with a list of personnel who are authorized to access to the DRCL command.)* Additional information:	☐	☐	☐
	Please provide copies of all required agreements, policies and procedures in force. The documentation will be returned when the Auditors finish their field work.			

19. Consolidated Request List

Number	Requested Item	Provided	Not Provided	Reason not provided
19.1	Electronic copy of any/all organizational policies, procedure(s) governing the access to, use	☐	☐	

Number	Requested Item	Provided	Not Provided	Reason not provided
	of and maintenance for the organization's core processing system.			
19.2	Copy of any/all 3rd party agreements with vendors who provide core processing services, software and/or hardware (include any/all Service Level Agreements and SAS 70s).	☐	☐	_____

20. Additional Information for the Auditor on Core Application System Security